

Caracas, 12 de febrero de 2026

Elaborado por: Gabriel Martinez

Empresa: Clinica Cardiovascular Santa Maria

1- Introducción

La implementación de políticas DLP en Clínica Cardiovascular Santa Elena permitirá establecer controles efectivos sobre el flujo de datos sensibles, especialmente en puntos críticos como dispositivos USB, correo electrónico, impresión y servicios en la nube.

2- Clasificación de los datos

Datos públicos: Información general, sin restricción de acceso. Por ejemplo: Folletos informativos sobre prevención cardiovascular, comunicados internos de bienestar, cartelería digital.

Datos internos: Información de uso exclusivo dentro de la clínica. Su divulgación no autorizada podría causar perjuicios moderados. Por ejemplo: Protocolos de enfermería, turnos médicos, inventario de insumos, manuales de equipos.

Datos sensibles: Información altamente confidencial, sujeta a regulación sanitaria. Su divulgación sería crítica. Por ejemplo: Historias clínicas, estudios hemodinámicos, ecocardiogramas, informes quirúrgicos

Esta clasificación será obligatoria al crear o almacenar cualquier documento digital y será el pilar para definir reglas de protección y monitoreo.

3- Acceso y Control: Principio del Menor Privilegio

Acceso Restringido: Los médicos solo accederán a las historias clínicas y estudios hemodinámicos de los pacientes a su cargo. El personal de enfermería visualizará exclusivamente signos vitales, medicación y cuidados asignados. El área administrativa gestionará turnos y facturación, sin acceso a diagnósticos o imágenes.

Revisión de permisos: Cada 90 días, el Comité de Seguridad junto con las jefaturas de Cardiología, Enfermería, Investigación y Administración revisarán los accesos activos en historia clínica, PACS y carpetas compartidas. Se revocarán aquellos permisos que no sean estrictamente necesarios para las funciones actuales del empleado.

Acceso Temporal: Cuando un médico de guardia requiera acceso a un estudio de un paciente no asignado, o un investigador necesite consultar un caso específico, se concederá acceso temporal con vigencia máxima de 72 horas, previa autorización formal del jefe de servicio. El acceso se revocará automáticamente al cumplirse el plazo.

Permisos de Edición Limitados: Solo los médicos tratantes y el personal de enfermería a cargo podrán registrar evolución, indicaciones y administración de fármacos. El resto del personal (administrativo, investigación, rotantes) tendrá permisos de solo lectura cuando requiera consultar información. Ningún usuario podrá modificar estudios de imagen ni informes finales.

Bloqueo de Dispositivos USB: Por defecto, todos los puertos USB estarán deshabilitados para almacenamiento masivo en estaciones clínicas y administrativas. Solo el personal de investigación y cardiólogos que presenten trabajos en congresos podrán solicitar USB corporativos cifrados, con autorización formal y registro de cada uso

4- Monitoreo y Auditoría

Se implementará una política de monitoreo y auditoría sobre el uso de datos sensibles para detectar accesos no autorizados y malas prácticas en la clínica:

Registro de Actividades: Se utilizarán las herramientas de auditoría del sistema de historia clínica para registrar quién accede a cada estudio cardiovascular, cuándo lo hace y qué acciones realiza (visualización, descarga, impresión, modificación).

Alertas de Seguridad: Se configurarán alertas automáticas en la solución DLP para notificar al departamento de Seguridad cuando se intente enviar por correo un estudio hemodinámico fuera del dominio corporativo, cuando se conecte un USB no autorizado o cuando un usuario descargue más de 50 historias clínicas en una hora.

Monitoreo de Dispositivos Extraíbles: Se implementará una herramienta de control de puertos USB que registrará cada intento de conexión de dispositivos externos. Cualquier uso de USB no autorizado generará una alerta inmediata y quedará registrado para su revisión disciplinaria.

Auditorías Trimestrales: El Comité de Seguridad realizará auditorías cada 90 días para revisar los accesos a documentos sensibles, especialmente historias clínicas de pacientes VIP, estudios de investigación en curso y registros financieros. Se documentarán hallazgos y se aplicarán medidas correctivas.

Integración con SIEM: Los eventos críticos detectados por el DLP y los sistemas de historia clínica serán enviados a una plataforma SIEM para correlacionar patrones de comportamiento anómalo, accesos en horarios inusuales o intentos de exfiltración de datos desde múltiples estaciones.

5- Prevención de filtraciones

Para prevenir la filtración de datos sensibles desde los sistemas de la clínica, se aplicarán las siguientes medidas:

Cifrado de Dispositivos: Todos los equipos portátiles (tabletas de enfermería, laptops médicas, equipos de hemodinamia) contarán con cifrado completo BitLocker o FileVault. Los USB autorizados serán exclusivamente corporativos y con cifrado por hardware.

Bloqueo de Correo Externo: Se deshabilitará por defecto el envío de correos electrónicos que contengan archivos adjuntos con datos personales de salud (historias clínicas, ecocardiogramas, informes quirúrgicos) hacia dominios externos no autorizados. Cualquier excepción deberá ser aprobada por la jefatura y utilizar cifrado de correo.

Compartir Controlado: La opción de compartir archivos desde plataformas en la nube corporativa con "cualquier persona con el enlace" será deshabilitada de manera predeterminada para todos los documentos clasificados como sensibles. Solo se podrá compartir con usuarios internos o externos previamente aprobados.

Protección con Etiquetas: Los documentos más sensibles (contratos de investigación, acuerdos con aseguradoras, historias clínicas de pacientes VIP) se protegerán con etiquetas de "Confidencial" o "Solo uso clínico". Estas etiquetas activarán reglas DLP que restringirán la descarga, impresión o reenvío no autorizado.

6- Educación y concientización

Es fundamental que todo el personal de la clínica, desde médicos hasta administrativos, comprenda la importancia de las políticas de seguridad en la protección de los datos de los pacientes:

Capacitaciones Obligatorias por Rol: Se impartirán capacitaciones trimestrales diferenciadas. El personal médico y de enfermería recibirá formación sobre manejo seguro de la historia clínica y riesgos del uso de USB. El equipo de investigación se capacitará en anonimización de datos y transferencia segura. Administrativos y personal de TI recibirán formación semestral adaptada a sus funciones.

Simulacros de Incidentes: Se realizarán simulacros controlados, como el envío de un correo falso con un archivo adjunto simulado de "estudio confidencial" a un grupo de empleados, para medir la reacción y el nivel de alerta. Los resultados se utilizarán para reforzar la capacitación sin exponer a los participantes.

7- Conclusión

La aplicación del Principio del Menor Privilegio y las políticas DLP en Clínica Cardiovascular Santa Elena garantizará la protección de los datos sensibles de los pacientes, reduciendo significativamente el riesgo de filtraciones y accesos no autorizados. La combinación de controles técnicos, auditorías periódicas y capacitación continua al personal permitirá fortalecer la seguridad de la información y cumplir con la normativa vigente.